



Full Length Article

Securing enterprise communications: Human-centric practices and emerging research

Guillermo Cotrina Cuenca ^a, Alberto Peinado Domínguez ^b^a Universidad Complutense de Madrid, Facultad de Ciencias Económicas y Empresariales, Departamento de Economía Financiera y Actuarial y Estadística, Campus de Somosaguas, 28223 Pozuelo de Alarcón, Madrid, Spain^b Universidad de Málaga, E.T.S.I. de Telecomunicación, Departamento de Ingeniería de Comunicaciones, Málaga, Spain

ARTICLE INFO

Keywords:

Enterprise communication security
 Phishing-resistant authentication
 Credential harvesting
 Passwordless authentication
 FIDO2 and WebAuthn
 Zero Trust architecture
 Human factors in cybersecurity
 Continuous authentication
 Device attestation
 AI-driven

ABSTRACT

Enterprises face increasingly sophisticated phishing and credential-harvesting campaigns, amplified by the use of generative Artificial Intelligence (AI) to produce context-specific and highly convincing lures. Although employee awareness and training remain necessary, extensive empirical evidence shows that their protective effects are modest, short-lived, and highly dependent on workflow fit. This paper argues that sustainable protection of enterprise communications requires embedding security measures directly into routine work through friction-minimizing, socio-technical alignment.

We synthesize recent interdisciplinary findings on human susceptibility, organizational dynamics, and attacker tactics, and we propose a strict, system-enforced, passwordless-first security model. The approach integrates phishing-resistant Multi-Factor Authentication (MFA), device attestation, continuous risk-based verification, and role-specific enablement, supported by measurable Key Performance Indicators (KPIs) and phased implementation gates.

By shifting from human-dependent vigilance to infrastructure-enforced controls, the proposed model provides a formally grounded basis for substantially suppressing credential-based compromise within the scope of the stated threat model and under explicit enforcement assumptions. Empirical validation through real-world deployment remains an important direction for future work.

1. Introduction

Securing enterprise communications has become an increasingly socio-technical challenge. Although advances in cryptographic protocols and secure system architectures remain indispensable, recent syntheses show that human and organizational factors frequently determine realized security outcomes in operational environments (Delso-Vicente et al., 2025). Information Security Policy (ISP) compliance is shaped not merely by awareness but by threat appraisal, response efficacy, task–technology fit, and person–organization fit (Hwang, 2025; Delso-Vicente et al., 2025). In day-to-day communication workflows, susceptibility to—and reporting of—phishing is further mediated by contextual and psychological determinants that vary across roles and organizational climates (Öner, 2025).

Taken together, these findings indicate that security posture is not solely a function of technical controls, but of the interaction between human decision processes and system design. Interventions that minimize cognitive friction and embed just-in-time guidance into routine workflows, while cultivating leadership-backed norms of psychological

safety, have been shown to improve reporting behavior and reduce silent failure modes (Sutton et al., 2025; Kim et al., 2025; Ho et al., 2025; Lain et al., 2024). However, the variance and temporal instability of human responses remain structurally significant.

Phishing exemplifies this socio-technical challenge. It remains one of the most prevalent and damaging initial access vectors against enterprises, enabling credential theft, business email compromise, and ransomware intrusions. Large-scale industry telemetry consistently attributes a substantial proportion of social-engineering-related breaches to credential harvesting and subsequent credential abuse (Verizon, 2025; Proofpoint, 2024). The sophistication of these campaigns is further amplified by generative AI, which produces context-specific, multilingual, and grammatically refined phishing content that erodes traditional user detection heuristics.

To mitigate phishing risks, organizations have widely adopted employee training programs and simulated phishing exercises. However, their effectiveness remains empirically bounded. Large-scale field evidence indicates that annual training and embedded simulations produce, at best, modest and short-lived reductions in susceptibility, with

* Corresponding author.

E-mail addresses: guicotri@ucm.es (G.C. Cuenca), apd@uma.es (A.P. Domínguez).

nontrivial relapse rates over time (Ho et al., 2025). Complementary studies show that embedded training often operates primarily as a periodic risk reminder rather than as durable knowledge acquisition, with engagement frequently reduced by workload pressure or perceived irrelevance (Lain et al., 2024). Additional incentive mechanisms targeting highly susceptible employees have not consistently improved outcomes and may introduce unintended cultural side effects (Lain et al., 2024).

These findings do not imply that awareness initiatives are ineffective; rather, they indicate that human-centered controls exhibit measurable variance, drift, and context dependence. As adversarial capabilities scale—particularly through automation and generative AI—defensive mechanisms that rely predominantly on discretionary human vigilance become increasingly fragile.

Consequently, scholars and practitioners advocate complementing behavioral interventions with strict, system-enforced technical controls. Phishing-resistant Multi-Factor Authentication (MFA), hardware-bound authentication, device attestation, Zero Trust architectures, and continuous verification mechanisms are increasingly recognized as foundational for reducing credential misuse and limiting post-compromise propagation (Verizon, 2025). Importantly, such controls shift critical security predicates from high-variance human decisions to infrastructure-enforced invariants. At the same time, sustainable enterprise resilience continues to depend on psychologically safe reporting cultures and leadership engagement (Delso-Vicente et al., 2025).

Taken together, current evidence supports a dual design principle: (i) reduce structural exposure to credential capture and replay through enforced technical constraints, and (ii) align socio-technical practices with human behavioral realities. Enterprises that systematically embed resilient authentication and per-request authorization into routine communication workflows are better positioned to reduce the probability and impact of credential-based compromise in an era shaped by AI-augmented social engineering.

Contributions. This paper makes three primary contributions. First, we synthesize recent interdisciplinary findings on phishing susceptibility, credential harvesting, and socio-technical determinants of communication security. Second, we introduce a formally specified, system-enforced, passwordless-first security model that integrates phishing-resistant authentication, device attestation, continuous verification, and propagation containment. Third, we provide a mathematically grounded rollout and evaluation framework with measurable KPIs, parameter estimation procedures, and alignment with European and Spanish regulatory instruments, enabling auditable and incremental enterprise adoption. All contributions are analytical and model-theoretic in nature; empirical validation through real-world deployment constitutes an explicit direction for future work, as discussed in the Limitations section and throughout the manuscript.

2. Phishing in contemporary enterprise contexts

Phishing has evolved into a multi-phase, multi-channel, and increasingly AI-augmented threat that exploits human trust and organizational communication patterns. Contemporary campaigns extend beyond generic mass email distribution: they are frequently targeted, context-aware, and coordinated across email, collaboration platforms, voice channels, and mobile environments (Verizon, 2025; Proofpoint, 2024). Large-scale breach telemetry consistently identifies credential abuse and phishing as dominant initial access pathways, highlighting the structural role of social engineering in enterprise compromise (Verizon, 2025).

A principal objective of contemporary campaigns is credential harvesting. Attackers deploy cloned login portals, spoofed Single Sign-On (SSO) prompts, and malicious Open Authorization (OAuth) consent flows against cloud productivity suites to capture authentication artifacts. These techniques are often combined with the use of previously

compromised internal identities to increase credibility and reduce detection likelihood (Delso-Vicente et al., 2025). Empirical breach data repeatedly shows that stolen credentials serve as enabling mechanisms for subsequent lateral movement, privilege escalation, and data exfiltration (Verizon, 2025). This pattern motivates the systematic reduction of reusable credential exposure and replay feasibility within enterprise environments.

Business Email Compromise (BEC) illustrates the economic and operational consequences of phishing-driven compromise. Adversaries impersonate executives, suppliers, or payroll personnel to manipulate financial processes or redirect payments, relying primarily on social and contextual manipulation rather than malware delivery. National incident statistics estimate multi-billion-dollar annual losses attributable to BEC, with sustained growth over recent reporting cycles (Federal Bureau of Investigation, Internet Crime Complaint Center (IC3), 2024; Federal Bureau of Investigation, 2025). These data underscore that the most financially damaging outcomes frequently arise from identity misuse rather than technical exploitation alone.

Phishing campaigns have also become intrinsically multi-channel. Email commonly acts as an entry vector, followed by voice-based (*vishing*) or SMS-based (*smishing*) reinforcement to increase plausibility and induce time pressure. This cross-channel coordination weakens traditional detection heuristics and challenges perimeter-based filtering models, particularly in distributed and hybrid enterprise environments (Proofpoint, 2024; Verizon, 2025).

Simultaneously, the integration of Generative Artificial Intelligence (GenAI) amplifies adversarial capability. Generative systems can produce linguistically fluent, role-specific, and multilingual phishing content; emulate executive communication styles; and generate synthetic media for impersonation. These capabilities reduce reliance on low-quality artifacts that previously served as detection cues and increase the baseline plausibility of malicious communications (Proofpoint, 2024; Verizon, 2025). As a result, phishing effectiveness becomes less dependent on linguistic imperfections and more dependent on structural workflow integration.

Finally, a substantial body of evidence challenges the stand-alone efficacy of awareness training in this evolving threat environment. Randomized Controlled Trials (RCTs) across multiple sectors demonstrate that annual training programs and embedded phishing simulations produce statistically measurable but temporally limited reductions in susceptibility, with relapse and variance across user groups (Ho et al., 2025; Lain et al., 2024). Rather than eliminating risk, such interventions modify behavioral distributions in bounded ways. The emerging consensus therefore favors a socio-technical approach: targeted education and behavioral nudging should be complemented by system-enforced mechanisms — including phishing-resistant MFA, device attestation, conditional access, and continuous verification — that reduce reliance on discretionary human detection (Delso-Vicente et al., 2025; Verizon, 2025).

3. Current uses of phishing in enterprises

Phishing in contemporary enterprises encompasses targeted credential theft, BEC, and cross-channel deception that blends email, voice, and mobile vectors. Industry telemetry consistently identifies phishing as a dominant precursor to breaches, with stolen credentials constituting a recurrent enabling factor in successful intrusions (Verizon, 2025). These patterns illustrate how adversaries increasingly exploit communication workflows and identity infrastructures rather than relying exclusively on software vulnerabilities.

Credential harvesting. A primary and persistent objective of phishing campaigns is the theft of authentication artifacts via cloned login portals, spoofed SSO prompts, and consent-grant attacks against cloud productivity environments. Large-scale breach analysis reports that within the *Basic Web Application Attacks* pattern, approximately 88% of breaches involved stolen credentials (Verizon, 2025). While this percentage refers to a specific breach classification category rather than to all breaches globally, it indicates the structural importance of credential misuse as an intrusion mechanism. This empirical concentration motivates the systematic reduction of reusable secret exposure and replay feasibility in enterprise environments.

BEC. BEC operations involve impersonation of executives, suppliers, or payroll staff to redirect payments or exfiltrate sensitive documents. Recent reporting indicates that 64% of surveyed organizations experienced BEC attempts in 2024, with typical per-incident financial losses in the six-figure range (Hoxhunt, 2025; Federal Bureau of Investigation, Internet Crime Complaint Center (IC3), 2024). These figures refer to survey-based exposure rates rather than confirmed breach rates; nevertheless, they highlight the financial materiality of identity misuse. Unlike malware-centric campaigns, BEC relies predominantly on authority cues, urgency, and contextual plausibility, reinforcing the role of identity compromise in enterprise risk.

Multi-channel campaigns. Phishing has become intrinsically multi-channel. Email frequently serves as the initial lure, followed by phone-based (*vishing*) or SMS-based (*smishing*) reinforcement to increase plausibility and induce rapid decision-making. Mid-year threat intelligence reports estimate that smishing accounted for roughly 45% of observed mobile threats during the reporting period (SlashNext Threat Labs, 2024; SlashNext, 2024). These statistics describe relative distribution within mobile threat categories rather than global incident prevalence, but they demonstrate the diversification of delivery vectors and the erosion of single-channel detection assumptions.

QR-based lures and evasive delivery. Attackers increasingly embed QR codes within phishing emails to circumvent URL filtering and redirect users toward mobile endpoints, a tactic commonly referred to as QR-based phishing (*quishing*). Reporting from 2024–2025 attributes approximately 11% of malicious email activity within certain datasets to quishing techniques (SlashNext, 2024; Infosecurity Magazine, 2024). Although percentages vary by dataset and detection methodology, the technique illustrates adaptive behavior in response to enterprise filtering controls.

GenAI-augmented social engineering. The integration of GenAI into phishing workflows amplifies adversarial capability by generating linguistically fluent, context-aware messages across multiple languages; mimicking executive communication styles; and enabling synthetic media for real-time impersonation. These affordances reduce reliance on easily detectable linguistic artifacts and increase baseline plausibility, particularly for roles responsible for financial approvals and credential-sensitive operations (Proofpoint, 2024; Verizon, 2025). The result is not a qualitative transformation of phishing, but a quantitative increase in scalability and personalization (see Fig. 1).

Overall, phishing in enterprise settings operates as a multi-phase, multi-channel, and increasingly AI-augmented threat that exploits communication patterns and identity workflows. Empirical findings from RCTs and field studies indicate that awareness training alone produces bounded and time-dependent effects on susceptibility (Ho et al., 2025; Lain et al., 2024). These observations support the subsequent formal analysis in which credential capture, post-compromise validity, and lateral propagation are treated as distinct probabilistic components that require structural suppression through enforced authentication and authorization controls (Verizon, 2025).

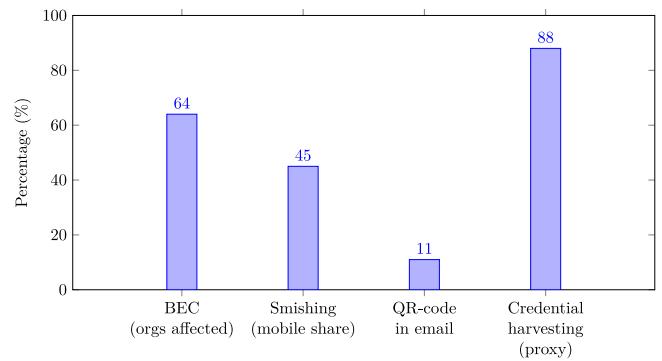


Fig. 1. Illustrative indicators of phishing usage patterns across distinct reporting categories: BEC exposure rate (survey-based) (Hoxhunt, 2025; Proofpoint, 2024); smishing share within mobile threat observations (SlashNext Threat Labs, 2024); QR-based phishing share within specific malicious email datasets (SlashNext, 2024); and credential involvement within the *Basic Web Application Attacks* breach pattern (Verizon, 2025). Percentages refer to different measurement universes and are not directly comparable.

4. Credential harvesting as the predominant phishing objective

Among the spectrum of phishing strategies, credential harvesting has become one of the most structurally significant tactics in enterprise environments. Rather than deploying malware at the initial stage, adversaries frequently target authentication artifacts — usernames, passwords, or MFA tokens — that can be reused to impersonate legitimate users and bypass identity-based trust assumptions. Once obtained, such credentials may enable privilege escalation, lateral movement, data exfiltration, or ransomware staging while preserving the appearance of authorized access within enterprise systems.

Large-scale threat intelligence reinforces the centrality of this vector. The Verizon DBIR (Verizon, 2025) reports that 88% of breaches classified under the *Basic Web Application Attacks* pattern involved stolen credentials. Although this percentage pertains to a specific breach category rather than all incidents globally, it illustrates the systemic role of credential misuse as an enabling mechanism for broader compromise. Attackers obtain credentials through high-fidelity replicas of login portals, spoofed SSO prompts, malicious Open Authorization (OAuth) consent requests, and increasingly adaptive email lures (Öner, 2025; Jabir et al., 2025). The strategic reuse of compromised internal accounts further increases plausibility and reduces detection probability (Delso-Vicente et al., 2025).

Human and organizational factors materially influence this exposure. Empirical evidence indicates that susceptibility to credential-focused phishing is mediated by perceived threat severity, self-efficacy, and alignment between personal and institutional values (Hwang, 2025; Delso-Vicente et al., 2025). Even security-aware employees may disclose credentials when confronted with authority cues, urgency, or contextually convincing pretexts, particularly when training is generic or poorly aligned with workflow demands (Ho et al., 2025; Öner, 2025). The integration of generative AI into phishing toolchains further increases scalability and personalization, reducing reliance on low-quality artifacts and increasing baseline plausibility (Jabir et al., 2025).

Given these dynamics, credential harvesting should be modeled as a primary enterprise risk component within broader compromise probability structures. In probabilistic terms, credential capture directly contributes to the initial factor

P_{capture}

in the multi-stage success decomposition introduced later in this manuscript. Reducing exposure at this stage has multiplicative downstream effects on post-compromise validity and lateral propagation probabilities.

Effective mitigation therefore requires a layered socio-technical strategy comprising:

- (i) role-specific user interventions that improve recognition of credential-oriented phishing and promote psychologically safe reporting channels (Sutton et al., 2025; Kim et al., 2025);
- (ii) technical controls such as phishing-resistant MFA (e.g., Fast Identity Online 2 (FIDO2) and Web Authentication (WebAuthn)), conditional access enforcement, and continuous session validation mechanisms; and
- (iii) organizational measures that reinforce accountability norms and reduce friction between security controls and operational workflows (Hwang, 2025).

Addressing credential harvesting at multiple layers reduces the probability that an adversary can both obtain reusable authentication artifacts and maintain exploitable access. While no single control eliminates credential-based risk, coordinated enforcement across authentication, session management, and organizational practice systematically suppresses this attack vector and constrains its downstream amplification potential (Delso-Vicente et al., 2025; Ho et al., 2025; Hwang, 2025).

5. Countermeasures against credential harvesting

Because credential harvesting is a structurally significant and operationally consequential objective in contemporary phishing campaigns, mitigating it is a central priority for enterprise security programmes. Both academic and industry literature identify a spectrum of countermeasures that are widely deployed, though with heterogeneous and context-dependent effectiveness. These range from user-focused interventions and secure authentication mechanisms to integrated detection-and-response capabilities (Hwang, 2025; Delso-Vicente et al., 2025; Öner, 2025; Verizon, 2025).

Established countermeasures

Current enterprise practice reflects a progressive convergence toward combined socio-technical approaches:

- **User-focused training and awareness.** Employees are educated to recognize credential-oriented phishing tactics, often through simulations and contextualized training modules. Empirical work consistently shows that such programmes are most effective when role-specific, embedded into daily workflows, and supported by psychologically safe reporting cultures; otherwise, protective effects are modest and short-lived (Hwang, 2025; Delso-Vicente et al., 2025; Ho et al., 2025).
- **Technical safeguards.** Phishing-resistant MFA, conditional access policies, reputation- and content-based email filtering, strict Domain-based Message Authentication, Reporting, and Conformance (DMARC) enforcement, and automated credential/session revocation collectively reduce exposure and shrink attacker exploitation windows. These controls form the backbone of contemporary enterprise authentication and communication security (Verizon, 2025; Proofpoint, 2024).
- **Organizational integration.** Security controls are increasingly embedded into routine communication workflows through unobtrusive banners, contextual warnings, and just-in-time prompts. Psychological safety and transparent escalation pathways further encourage early reporting and reduce the social costs associated with admitting potential mistakes (Sutton et al., 2025; Kim et al., 2025; Ho et al., 2025).

Taken together, these measures can meaningfully decrease the likelihood and impact of credential compromise. However, effectiveness remains bounded by behavioral variability and implementation heterogeneity. As adversaries leverage generative GenAI to produce highly persuasive, context-specific phishing content (Jabir et al., 2025), the limitations of awareness-dependent defenses become more pronounced. This motivates stronger, system-enforced controls that minimize reliance on discretionary human action.

Strict and systematic measures: proposed contribution

The preceding analysis indicates that prevailing enterprise defenses against credential harvesting remain fragmented, reactive, and structurally dependent on user attentiveness. Empirical evidence shows that user behavior under phishing stimuli exhibits high variance, strong context dependence, and non-stationary dynamics over time (Ho et al., 2025; Lain et al., 2024; Öner, 2025; Hwang, 2025; Delso-Vicente et al., 2025). Formally, let H denote a random variable capturing user response (e.g., click, report, ignore) to phishing attempts. Available studies suggest that $\text{Var}(H)$ is large and that the distribution of H drifts under workload, stress, and organizational climate (Sutton et al., 2025; Kim et al., 2025). Whenever H is allowed to act as a control predicate for credential protection, the enterprise effectively embeds a poorly controlled stochastic process into its security architecture.

In this subsection, we propose a suite of strict and systematic measures that reconceptualise credential protection not as a behavioral expectation but as an infrastructure-enforced property. The core contribution is twofold: (i) a system design that makes credential harvesting asymptotically unattractive and operationally difficult, and (ii) a mathematical framework that characterizes this design in terms of stochastic processes, queueing models, and rigorously stated bounds on adversarial success under explicit assumptions.

1. Passwordless-only authentication as attack-surface elimination (formal risk suppression).

Let C_{static} denote the set of reusable, user-controlled secrets (passwords, recovery phrases) and C_{phy} the set of device-bound, origin-specific credentials (e.g., FIDO2/WebAuthn passkeys). Under password-based authentication, define events

$$E_{\text{cap}} := \{\text{credential capture via phishing/consent}\},$$

$$E_{\text{guess}} := \{\text{guessing/stuffing succeeds}\},$$

$$E_{\text{replay}} := \{\text{replay of captured secret succeeds}\}.$$

Since these events are not necessarily disjoint, a conservative bound for compromise is the union bound

$$\begin{aligned} \Pr(\text{compromise}) &= \Pr(E_{\text{cap}} \cup E_{\text{guess}} \cup E_{\text{replay}}) \\ &\leq \Pr(E_{\text{cap}}) + \Pr(E_{\text{guess}}) + \Pr(E_{\text{replay}}), \end{aligned}$$

where each term is typically non-negligible in enterprise environments due to phishing, password reuse, brute force, and credential stuffing (Verizon, 2025; Proofpoint, 2024).

In a passwordless-only regime, we enforce

$$C_{\text{static}} = \emptyset, \quad C = C_{\text{phy}},$$

and require origin binding and verifier-side enforcement consistent with FIDO2/WebAuthn. Under this threat model, the replay class of attacks against reusable secrets is structurally removed, and the probability mass of E_{replay} is suppressed toward zero:

$$\Pr(E_{\text{replay}}) \leq \epsilon_{\text{replay}},$$

where $\epsilon_{\text{replay}} \rightarrow 0$ as origin binding and passwordless-only coverage become comprehensive.

Similarly, large-scale capture mechanisms that rely on reusable secrets (password phishing, credential stuffing) are suppressed: as

$c_{\text{pwdless}} \rightarrow 1$, passwordless-only enforcement eliminates fallback to reusable secrets, driving

$$\Pr(E_{\text{cap}}) \leq \varepsilon_{\text{cap}} \rightarrow 0.$$

This limiting statement holds asymptotically in the coverage parameter $c_{\text{pwdless}} \in [0, 1]$. For any finite coverage level $c_{\text{pwdless}} < 1$, ε_{cap} remains strictly positive and is bounded below by $(1 - c_{\text{pwdless}}) \cdot p_{\text{capture}}^{\text{pwd}}$, as formalized in the sensitivity analysis of Section 7.2.

Residual compromise probability is then dominated by endpoint/device compromise and recovery-path exceptions, rather than scalable credential-harvesting pipelines (Verizon, 2025; Proofpoint, 2024; Jabir et al., 2025). This represents a categorical shift from knowledge-based authentication to hardware-and-context-bound authentication and *substantially suppresses* a major class of scalable credential-harvesting vectors, subject to comprehensive passwordless-only enforcement and the absence of fallback authentication mechanisms—conditions that must be explicitly verified and continuously monitored in any given deployment.

2. Continuous re-authentication as a Markovian decay process (decoupled arrivals and conditional lifetime).

Traditional session management implicitly assumes that once authenticated, a principal remains trusted until explicit logout or a coarse session timeout. This assumption is unsafe in adversarial settings because session misuse is governed by (i) how frequently compromises occur and (ii) how long a compromise remains exploitable once it occurs. To avoid conflating these two phenomena, we *decouple* the *arrival process* of compromise events from the *conditional decay* (invalidation) of a session after compromise.

(i) Compromise arrivals. Let compromise events against authenticated sessions (e.g., token theft, session hijack, or successful phishing that results in an active session) be modeled as a counting process $N_{\text{comp}}(t)$ with intensity λ_{comp} (e.g., Poisson as a first-order approximation):

$$\mathbb{E}[N_{\text{comp}}(t)] = \lambda_{\text{comp}} t.$$

The parameter λ_{comp} captures *frequency* of successful compromises as observed in enterprise telemetry and breach analyses (Verizon, 2025; Proofpoint, 2024). Importantly, λ_{comp} governs *how often* compromise occurs, but not *how long* an already-compromised session remains usable.

(ii) Conditional exploitation lifetime as competing risks. Condition on the event that a session becomes compromised at time $t = 0$. Let L denote the *usable exploitation lifetime* of that compromised session. We model invalidation via independent exponential hazards driven by defender-controlled mechanisms:

- enforced re-authentication at rate $\rho = 1/\tau$ (maximum re-authentication interval τ);
- detection-and-revocation at rate μ_{rev} ;
- optional hard expiry/rotation at rate δ_{exp} .

Define the total invalidation hazard

$$\kappa := \rho + \mu_{\text{rev}} + \delta_{\text{exp}}.$$

Then

$$\Pr(L > t) = e^{-\kappa t}, \quad \mathbb{E}[L] = \frac{1}{\kappa} = \frac{1}{\rho + \mu_{\text{rev}} + \delta_{\text{exp}}}.$$

This expresses rigorously that post-compromise utility is controlled by *defender-enforced* rates and shrinks monotonically as ρ , μ_{rev} , and/or δ_{exp} increase, consistent with evidence that user-dependent controls exhibit high variance and drift (Ho et al., 2025; Lain et al., 2024; Öner, 2025; Hwang, 2025; Delso-Vicente et al., 2025; Sutton et al., 2025; Kim et al., 2025).

(iii) CTMC representation (post-compromise state). Equivalently, define a CTMC on $\{C_0 : \text{compromised but active}, C_1 : \text{revoked}\}$ with generator

$$Q_C = \begin{pmatrix} -\kappa & \kappa \\ 0 & 0 \end{pmatrix}, \quad P_{C_0 C_0}(t) = e^{-\kappa t}.$$

This makes explicit that decay is a *post-compromise* property and should not include λ_{comp} .

(iv) Aggregating frequency and duration. Define cumulative compromised time over horizon T :

$$\mathcal{T}_{\text{comp}}(T) := \sum_{i=1}^{N_{\text{comp}}(T)} L_i,$$

with L_i i.i.d. copies of L independent of $N_{\text{comp}}(T)$ (compound Poisson model). Then

$$\mathbb{E}[\mathcal{T}_{\text{comp}}(T)] = \lambda_{\text{comp}} T \cdot \frac{1}{\rho + \mu_{\text{rev}} + \delta_{\text{exp}}}.$$

This separates compromise *frequency* from exploitation *duration* and provides direct engineering levers.

(v) Regimes. If $\rho \gg \mu_{\text{rev}} + \delta_{\text{exp}}$, then $\Pr(L > t) \approx \exp(-t/\tau)$ and $\mathbb{E}[L] \approx \tau$; if not, the model remains exact with κ .

3. Queueing model for re-authentication and availability–security trade-offs.

Continuous verification induces additional authentication load. To guarantee that security does not come at the expense of system instability, we model the re-authentication subsystem as an $M/M/1$ queue. Let λ_{req} denote the arrival rate of re-authentication requests and μ_{srv} the service rate of the authentication backend. The stability condition is

$$\rho_{\text{queue}} = \frac{\lambda_{\text{req}}}{\mu_{\text{srv}}} < 1.$$

Under standard $M/M/1$ assumptions, the expected waiting time in the system (including service) is

$$\mathbb{E}[W] = \frac{1}{\mu_{\text{srv}} - \lambda_{\text{req}}}.$$

Given a target maximum latency W_{max} , a sufficient capacity constraint is

$$\mu_{\text{srv}} \geq \lambda_{\text{req}} + \frac{1}{W_{\text{max}}}.$$

This yields an analytically tractable security–usability design coupling between (τ, ρ) and backend capacity.

4. Strict device attestation as endpoint feasibility reduction.

Device attestation constrains access to endpoints that can produce cryptographic evidence of integrity and policy compliance (e.g., via TPM/TEE). Let $\mathcal{D}$ denote the set of devices capable of connecting to enterprise services and $\mathcal{A} \subseteq \mathcal{D}$ the subset of attested, policy-compliant devices. Define the empirical attestation coverage

$$S_{\text{eff}} := \frac{|\mathcal{A}|}{|\mathcal{D}|}.$$

Strict enforcement denies access from $\mathcal{D} \setminus \mathcal{A}$, thereby restricting feasible access to attested endpoints. Rather than asserting empty feasibility sets, we express suppression probabilistically: if P_{device} denotes the probability that an adversary can satisfy device posture constraints for an attempted access, then stronger enforcement and higher-quality attestation reduce P_{device} (and hence downstream success probability) by shrinking the feasible endpoint surface, subject to exceptions and the stated threat model.

5. Per-request Zero Trust validation as a graph-theoretic constraint (without hop-independence).

Enterprise communications can be represented as a directed graph $G = (V, E)$, where V denotes identities/services/endpoints and $(i, j) \in E$ denotes feasible access transitions. Zero Trust replaces transitive trust with per-request authorization evaluated against identity, device posture, context, and risk (Verizon, 2025). Because lateral movement is correlated and topology is heterogeneous, we avoid hop-independence and use a matrix-analytic multi-type branching approximation.

Let $M \in \mathbb{R}_{\geq 0}^{|V| \times |V|}$ encode baseline pivot feasibility weights, and let $P \in [0, 1]^{|V| \times |V|}$ be a gating matrix where P_{ij} is the probability that (i, j)

is authorized under Zero Trust controls. Define the effective movement matrix

$$M' = P \circ M.$$

Let Z_t denote the vector of compromised nodes at step t . First-moment dynamics satisfy $\mathbb{E}[Z_{t+1} | Z_t] \approx Z_t M'$, hence $\mathbb{E}[Z_t] \approx Z_0 (M')^t$. A sufficient condition for extinction is subcriticality of the mean offspring matrix:

$$\rho(M') < 1 \implies \Pr(\text{eventual extinction}) = 1,$$

with geometric decay $\| \mathbb{E}[Z_t] \| \leq C \rho(M')^t$ for suitable norm and constant C . This criterion captures privilege hubs and correlated success via the structure of M and targeted suppression in P , aligning with enterprise risk where privileged pathways dominate propagation (Verizon, 2025; Federal Bureau of Investigation, Internet Crime Complaint Center (IC3), 2024).

6. Compulsory privileged credential rotation and expiry.

High-value credentials (e.g., administrative tokens, service accounts) are rotated on bounded intervals. Let T denote the rotation period and X the compromise time of a credential. The usable horizon is

$$W = \max\{0, T - X - \delta\},$$

where δ is expected detection delay. If $X \sim \text{Uniform}[0, T]$, then

$$\mathbb{E}[W] = \frac{T}{2} - \delta.$$

Shortening T and reducing δ shrink the expected misuse window, thereby reducing attacker utility. If $U_{\text{adv}}(T) = G \cdot \mathbb{E}[W] - C$, sufficiently small T implies $U_{\text{adv}}(T) < 0$, making abuse economically irrational under the model.

7. Integrated bound on adversarial success (rigorous, no absolute zeros).

Let overall success be decomposed as

$$P_{\text{succ}} = P_{\text{capture}} \cdot P_{\text{valid|capture}} \cdot P_{\text{device}} \cdot P_{\text{lateral}}.$$

where:

- P_{capture} captures acquisition of reusable authentication artifacts or session material;
- $P_{\text{valid|capture}}$ captures post-capture persistence (session validity over required time);
- P_{device} captures satisfaction of device posture/attestation constraints;
- P_{lateral} captures propagation to target assets.

Under the post-compromise lifetime model, if an attacker requires an exploitation duration of at least $t > 0$ after capture, then

$$P_{\text{valid|capture}} = \Pr(L > t) = e^{-\kappa t}, \quad \kappa = \rho + \mu_{\text{rev}} + \delta_{\text{exp}}.$$

Under Zero Trust gating with effective matrix $M' = P \circ M$, propagation is suppressed as policies reduce $\rho(M')$; in the subcritical regime $\rho(M') < 1$, propagation dies out almost surely in the branching approximation, and expected spread decays geometrically. Accordingly, the strict measures suppress each factor without requiring any of them to be identically zero:

$$P_{\text{capture}} \leq \varepsilon_{\text{cap}}, \quad P_{\text{valid|capture}} = e^{-\kappa t}, \quad P_{\text{device}} \leq \varepsilon_{\text{dev}},$$

P_{lateral} decreases as $\rho(M') \downarrow$,

with $\varepsilon_{\text{cap}}, \varepsilon_{\text{dev}}$ determined by enforcement coverage and residual channels. Their conjunction yields multi-dimensional suppression of P_{succ} that is asymptotically strong as enforcement tightens (Verizon, 2025; Proofpoint, 2024; Jabir et al., 2025).

8. Summary of the contribution.

The novel contribution of this paper is to articulate and formalize a credential-protection model in which security is no longer a

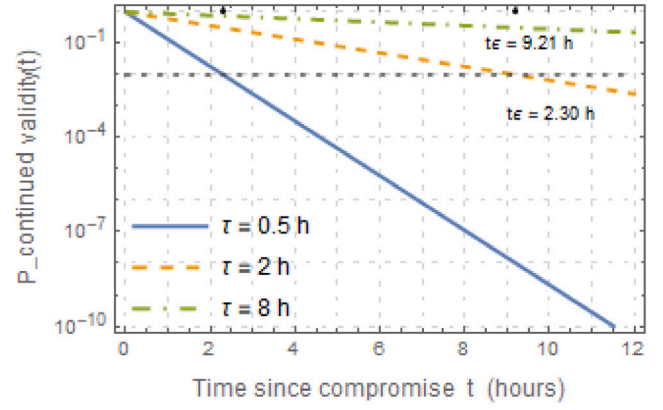


Fig. 2. Exponential decay of the probability that a compromised session remains valid, $P_{\text{continued validity}}(t) = \exp(-t/\tau)$ as a special case of $\Pr(L > t) = e^{-\kappa t}$ when $\rho = 1/\tau$ dominates other invalidation hazards. The vertical dashed guides mark $t_\epsilon = \tau \ln(1/\epsilon)$ for selected thresholds, with labels positioned at the bottom to reduce visual clutter. Extending the logarithmic y-axis down to 10^{-10} ensures full visibility of fast-decaying scenarios (e.g., $\tau = 0.5$ h).

stochastic by-product of user vigilance but an infrastructure-enforced property governed by measurable control parameters. Training and awareness remain valuable (Ho et al., 2025; Lain et al., 2024), yet their empirically observed variance and decay over time (Öner, 2025; Delso-Vicente et al., 2025; Hwang, 2025) preclude their use as primary controls. By contrast, the proposed strict measures—passwordless-only FIDO2/WebAuthn authentication, continuous re-authentication with invalidation hazard κ , strict device attestation, per-request Zero Trust validation characterized by $\rho(M')$, and compulsory privileged credential rotation—systematically suppress the adversary’s feasible strategy space and yield analytically tractable bounds on exploitation windows and propagation.

In doing so, the framework advances current socio-technical practice by aligning organizational, human, and technical dimensions with a formally analysable security posture. Credential harvesting is thereby repositioned from a structurally favored attack vector (Verizon, 2025; Proofpoint, 2024; Jabir et al., 2025) to a residual risk component whose probability of success can be made arbitrarily small under progressively stricter enforcement, *strictly within the stated threat model and conditional on full passwordless-only coverage, comprehensive device attestation, subcritical Zero Trust gating ($\rho(M') < 1$), and enforcement parameters approaching their theoretical limits*—conditions that are unlikely to be simultaneously satisfied in operational enterprise environments (see Fig. 2).

6. Business impact and rollout plan

This section formalizes the enterprise-wide impact of adopting a strict, system-enforced, passwordless-first and Zero Trust-aligned architecture. Unlike prior qualitative assessments, we model (i) security, operational, and financial benefits using explicit stochastic-risk and queueing frameworks, and (ii) the rollout structure as a staged control process with quantifiable efficiency gains. The rationale follows empirical evidence: training-only interventions exhibit steep temporal decay in effectiveness (Ho et al., 2025; Lain et al., 2024; Hwang, 2025; Delso-Vicente et al., 2025); credential-centric compromise remains a dominant intrusion vector (Verizon, 2025); BEC losses create sustained financial exposure (Federal Bureau of Investigation, Internet Crime Complaint Center (IC3), 2024); and GenAI increases adversarial capability (Jabir et al., 2025). The proposed model shifts risk control from high-variance human behavior to lower-variance, infrastructure-enforced controls with measurable parameters.

6.1. Expected benefits for adopting organizations: A mathematical and economic view

(1) *Security outcomes (suppression without absolute zeros).* Let

$$\lambda_{\text{cred}}^{\text{att}}, \quad \lambda_{\text{bec}}^{\text{att}}, \quad \lambda_{\text{post}}^{\text{att}}$$

denote attempt intensities (per unit time) for (i) credential-harvesting/credential-based intrusion attempts, (ii) BEC attempts, and (iii) post-phish lateral-movement attempts, respectively, as observed in SIEM telemetry. For each category $j \in \{\text{cred}, \text{bec}, \text{post}\}$ let p_j be the conditional success probability under baseline controls. Define the successful-event intensity

$$\lambda_j := \lambda_j^{\text{att}} p_j.$$

Over horizon T , model successful events as $N_j(T) \sim \text{Poisson}(\lambda_j T)$ (first-order approximation). Then

$$\mathbb{E}[N_j(T)] = \lambda_j T = \lambda_j^{\text{att}} p_j T.$$

Under passwordless-only authentication, continuous verification, strict device attestation, and Zero Trust gating, do *not* assume $p_j = 0$; instead, model multiplicative suppression

$$p'_j = \theta_j p_j, \quad \theta_j \in (0, 1),$$

with θ_j capturing enforcement coverage and residual channels (end-point compromise, recovery-path abuse, policy exceptions). The post-control expected number of successes becomes

$$\mathbb{E}[N'_j(T)] = \lambda_j^{\text{att}} p'_j T = \theta_j \lambda_j^{\text{att}} p_j T = \theta_j \mathbb{E}[N_j(T)].$$

In particular, consistent with breach telemetry emphasizing credential abuse as a leading driver (Verizon, 2025; Proofpoint, 2024), well-enforced passwordless-first architectures seek $\theta_{\text{cred}} \ll 1$ by suppressing scalable credential capture and replay.

(2) *Queueing-theoretic impact on incident response (SOC $M/M/s$ with Erlang C).* We model the incident-response (IR) pipeline of the Security Operations Center (SOC) as an $M/M/s$ queue: Poisson arrivals, exponential service times, s homogeneous analysts (servers), first-come-first-served discipline. Let $\lambda > 0$ denote the arrival rate of actionable alerts (per unit time) and $\mu > 0$ the service rate per analyst (cases per unit time), so total service capacity is $s\mu$.

Define offered load (Erlangs) and utilization:

$$a := \frac{\lambda}{\mu}, \quad u := \frac{\lambda}{s\mu} = \frac{a}{s}.$$

Stability requires

$$u < 1 \Leftrightarrow \lambda < s\mu.$$

Erlang C probability of waiting. The probability that an arriving alert must wait is

$$P_{\text{wait}}(\lambda, \mu, s) = \frac{\frac{a^s}{s!} \cdot \frac{1}{1-u}}{\sum_{n=0}^{s-1} \frac{a^n}{n!} + \frac{a^s}{s!} \cdot \frac{1}{1-u}}, \quad a = \frac{\lambda}{\mu}, \quad u = \frac{\lambda}{s\mu}, \quad u < 1.$$

The expected waiting time in queue and the expected total time in system are

$$\mathbb{E}[W_q] = \frac{P_{\text{wait}}(\lambda, \mu, s)}{s\mu - \lambda}, \quad \mathbb{E}[W] = \mathbb{E}[W_q] + \frac{1}{\mu}.$$

These expressions are exact for the $M/M/s$ model and capture the nonlinear dependence of delay on utilization u .

Effect of strict authentication and attestation. Let strict enforcement reduce the actionable-alert arrival rate multiplicatively:

$$\lambda' = \alpha \lambda, \quad 0 < \alpha < 1.$$

Then

$$a' = \frac{\lambda'}{\mu} = \alpha a, \quad u' = \frac{\lambda'}{s\mu} = \alpha u,$$

and the new expected waiting time is

$$\mathbb{E}[W'_q] = \frac{P_{\text{wait}}(\alpha \lambda, \mu, s)}{s\mu - \alpha \lambda}.$$

Monotonicity and sensitivity (rigorous statements). For fixed (μ, s) with $u < 1$, $\mathbb{E}[W_q]$ is strictly increasing in λ on $(0, s\mu)$ and

$$\lim_{\lambda \uparrow s\mu} \mathbb{E}[W_q] = +\infty.$$

Hence, when the SOC operates near capacity ($u \approx 1$), even moderate reductions in λ yield disproportionately large reductions in $\mathbb{E}[W_q]$ due to the combined effect of (i) the factor $(s\mu - \lambda)^{-1}$ and (ii) the rapid decrease of P_{wait} as u moves away from 1. This implies improved responsiveness and reduced backlog pressure, thereby supporting reductions in MTTD and MTTR.

Model assumptions and interpretation. The $M/M/s$ model assumes memoryless arrivals and service times. Real alert streams may be bursty, priority-routed, and have non-exponential resolution times; in such cases, Erlang C serves as a first-order analytic baseline. The qualitative implication remains robust: reducing actionable arrival intensity strictly decreases expected delay, with amplified gains near the stability boundary, consistent with the operational motivation for reducing credential-driven alert volumes (Verizon, 2025).

(3) *Diffusion-model suppression of lateral movement (from scalar R_0 to spectral threshold).* Let $G = (V, E)$ be the enterprise communication graph. A scalar branching approximation writes a basic reproduction number

$$R_0 := \beta \cdot \mathbb{E}[\text{reachable nodes per compromised node}],$$

where $\beta \in [0, 1]$ is a per-edge movement success probability in a simplified homogeneous model. Zero Trust gating can be represented as multiplicative suppression $\beta' = p\beta$ with $p \in (0, 1)$, yielding $R'_0 = pR_0$ and the classical sufficient condition

$$R'_0 < 1 \Rightarrow \Pr(\text{extinction}) = 1$$

in the idealized branching model.

To align with correlated lateral movement and heterogeneous topology (as discussed earlier), we restate the same containment principle using the mean offspring matrix $M' = P \circ M$ and its spectral radius:

$$\rho(M') < 1 \Rightarrow \Pr(\text{eventual extinction}) = 1,$$

which generalizes the scalar R_0 condition and avoids hop-independence while preserving the “containment by default” interpretation (Federal Bureau of Investigation, Internet Crime Complaint Center (IC3), 2024; Verizon, 2025).

6.2. Economic impact: Formal cost models

Expected loss as a compound loss functional. Let incident categories be indexed by $i \in I$ (e.g., credential-based account compromise, BEC, ransomware enabled by credential abuse). Over a one-year horizon, model the number of incidents of type i as N_i with mean rate λ_i (incidents/year). Let C_i denote the (random) loss severity per incident of type i , with finite mean $\mathbb{E}[C_i]$. The total annual loss is the compound sum

$$X_0 = \sum_{i \in I} \sum_{k=1}^{N_i} C_{i,k},$$

where $\{C_{i,k}\}_{k \geq 1}$ are i.i.d. copies of C_i , independent of N_i . Under a Poisson frequency approximation $N_i \sim \text{Poisson}(\lambda_i)$,

$$\mathbb{E}[X_0] = \sum_{i \in I} \mathbb{E}[N_i] \mathbb{E}[C_i] = \sum_{i \in I} \lambda_i \mathbb{E}[C_i].$$

To connect with the common *attempt* $\times$ *success* $\times$ *cost* decomposition, write $\lambda_i = \lambda_i^{\text{att}} p_i$ where λ_i^{att} is an attempt intensity and p_i a conditional success probability. Then

$$\mathbb{E}[X_0] = \sum_{i \in I} \lambda_i^{\text{att}} p_i \mathbb{E}[C_i].$$

Consistent with breach evidence that credential abuse is a dominant intrusion pathway (Verizon, 2025; Proofpoint, 2024), the credential-compromise component is often a leading term:

$$\mathbb{E}[X_0] \approx \lambda_{\text{cred}}^{\text{att}} p_{\text{cred}} \mathbb{E}[C_{\text{cred}}].$$

Control impact as proportional suppression (no absolute zeros). Under passwordless-only enforcement, strict device attestation, continuous verification, and Zero Trust gating, success probabilities are suppressed but not assumed identically zero. Model suppression by

$$p'_i = \theta_i p_i, \quad \theta_i \in (0, 1),$$

where θ_i captures enforcement coverage and residual channels. Let post-control incident counts satisfy the thinned Poisson approximation

$$N'_i \sim \text{Poisson}(\lambda_i^{\text{att}} p'_i) = \text{Poisson}(\theta_i \lambda_i^{\text{att}} p_i).$$

Let post-control severities be $C'_{i,k}$ with mean $\mathbb{E}[C'_i]$ (allowing for reduced dwell time/containment). Then

$$\mathbb{E}[X_1] = \sum_{i \in I} \mathbb{E}[N'_i] \mathbb{E}[C'_i] = \sum_{i \in I} \theta_i \lambda_i^{\text{att}} p_i \mathbb{E}[C'_i].$$

A conservative bound holds by setting $\mathbb{E}[C'_i] = \mathbb{E}[C_i]$:

$$\mathbb{E}[X_1] = \sum_{i \in I} \theta_i \lambda_i^{\text{att}} p_i \mathbb{E}[C_i] < \sum_{i \in I} \lambda_i^{\text{att}} p_i \mathbb{E}[C_i] = \mathbb{E}[X_0].$$

In particular, for credential-based compromise,

$$\mathbb{E}[X_1]_{\text{cred}} = \theta_{\text{cred}} \lambda_{\text{cred}}^{\text{att}} p_{\text{cred}} \mathbb{E}[C_{\text{cred}}], \quad \theta_{\text{cred}} \ll 1$$

in well-enforced environments (Verizon, 2025; Proofpoint, 2024).

Risk-averse decision criterion via expected utility (CARA; stochastic dominance rigorously stated). Let X_0 and X_1 denote the annual loss random variables before and after enforcement of the proposed controls (Section 6.2). We model risk-averse preferences over monetary losses using constant absolute risk aversion (CARA) utility that is strictly *decreasing* in loss:

$$U(X) = -e^{\gamma X}, \quad \gamma > 0,$$

where X denotes loss. Since

$$U'(X) = -\gamma e^{\gamma X} < 0,$$

larger losses imply strictly lower utility, so smaller losses are preferred.

First-order stochastic dominance (loss domain).

We say that X_1 is stochastically smaller than X_0 (first-order stochastic dominance for losses) if

$$F_{X_1}(t) \geq F_{X_0}(t) \quad \forall t \in \mathbb{R}, \quad \text{equivalently}$$

$$\Pr(X_1 > t) \leq \Pr(X_0 > t) \quad \forall t.$$

A standard result in decision theory states that for any strictly *decreasing* utility function U ,

$$X_1 \leq_{\text{st}} X_0 \implies \mathbb{E}[U(X_1)] \geq \mathbb{E}[U(X_0)],$$

with strict inequality whenever dominance is strict on a set of positive measure. Hence, if post-control losses are stochastically smaller, risk-averse decision makers strictly prefer X_1 .

Sufficient construction via independent Poisson thinning.

Consider the compound loss representation

$$X_0 = \sum_{i \in I} \sum_{k=1}^{N_i} C_{i,k},$$

where $N_i \sim \text{Poisson}(\lambda_i)$ are independent across i , and severities $C_{i,k}$ are i.i.d. with finite mean and independent of counts.

Assume that post-control event counts arise via independent thinning:

$$N'_i \mid N_i \sim \text{Binomial}(N_i, \theta_i), \quad \theta_i \in (0, 1),$$

independently across i . Standard Poisson thinning implies

$$N'_i \sim \text{Poisson}(\theta_i \lambda_i),$$

and independence across i is preserved.

If severities are unchanged in distribution,

$$C'_{i,k} \stackrel{d}{=} C_{i,k},$$

and remain independent of counts, then

$$X_1 = \sum_{i \in I} \sum_{k=1}^{N'_i} C'_{i,k}$$

is a compound Poisson sum with strictly smaller intensity parameters.

Under these conditions,

$$X_1 \leq_{\text{st}} X_0.$$

The dominance follows because each independent Poisson component is thinned (reducing event frequency), and compound sums preserve stochastic ordering under independent reduction of counts.

Therefore,

$$\mathbb{E}[U(X_1)] > \mathbb{E}[U(X_0)] \quad (\gamma > 0),$$

without requiring $P_{\text{succ}} = 0$.

If, in addition, severities are stochastically reduced (e.g., shorter exploitation windows reduce impact magnitude), the dominance becomes strictly stronger.

Certainty-equivalent interpretation (loss domain).

For monetary interpretability, define the *loss certainty equivalent*

$$CE_{\text{loss}}(X) = \frac{1}{\gamma} \ln(\mathbb{E}[e^{\gamma X}]),$$

which satisfies

$$U(CE_{\text{loss}}(X)) = \mathbb{E}[U(X)].$$

Lower CE_{loss} is preferred. The risk-averse economic gain from the controls is

$$\Delta CE := CE_{\text{loss}}(X_0) - CE_{\text{loss}}(X_1).$$

Thus, $\Delta CE > 0$ indicates improvement under absolute risk aversion, capturing both mean reduction and tail-risk attenuation through the exponential weighting.

Productivity and helpdesk cost (volume reduction). Let helpdesk tickets (e.g., password resets and account recovery) arrive at rate $\lambda_h > 0$ with average handling cost $c_h > 0$. The expected monthly cost is

$$C_h = \lambda_h c_h.$$

Under passwordless-first enforcement, suppose arrival volume is multiplicatively reduced by $\beta \in (0, 1)$:

$$\lambda'_h = \beta \lambda_h.$$

Then

$$C'_h = \lambda'_h c_h = \beta C_h,$$

yielding a strictly proportional reduction in operational expenditure. This formulation is distribution-agnostic and does not rely on exponential service assumptions.

BEC expected loss under strong verification. Let $\lambda_{\text{bec}}^{\text{att}}$ denote the intensity of BEC attempts and p_{bec} the baseline success probability. Under verified-by-default communications and strict approval verification, model suppression as

$$p'_{\text{bec}} = \theta_{\text{bec}} p_{\text{bec}}, \quad \theta_{\text{bec}} \in (0, 1),$$

so

$$\mathbb{E}[X_1]_{\text{bec}} = \lambda_{\text{bec}}^{\text{att}} p'_{\text{bec}} \mathbb{E}[C_{\text{bec}}] = \theta_{\text{bec}} \lambda_{\text{bec}}^{\text{att}} p_{\text{bec}} \mathbb{E}[C_{\text{bec}}].$$

Given that BEC incidents can be high-severity ([Federal Bureau of Investigation, Internet Crime Complaint Center \(IC3\), 2024](#)), even moderate suppression (e.g., $\theta_{\text{bec}} \approx 0.2$) yields substantial absolute expected-loss reduction and reduces tail exposure under risk aversion.

6.3. Key Performance Indicators (KPIs): Formalized

Let $X(t)$ denote a KPI time series indexed by continuous time $t \geq 0$ (to avoid notational collision with random variables used elsewhere). A simple convergence model is

$$X(t) = X_{\infty} + (X(0) - X_{\infty})e^{-kt}, \quad k > 0,$$

where k is a policy-induced convergence rate. For credential-related incident KPIs, the asymptote is small under strict enforcement:

$$X_{\infty} \approx 0, \quad k \text{ large under strong rollout and enforcement.}$$

This provides a tractable parametric model for target trajectories. It must be noted, however, that $X_{\infty} \approx 0$ is a model-theoretic limiting value attained as enforcement coverage approaches unity, not an operationally achievable target. In practice, X_{∞} will remain strictly positive due to partial coverage, policy exceptions, and residual attack surface. The convergence rate k is likewise a modeling construct whose empirical calibration requires longitudinal telemetry data not available in the present work.

6.4. Phased rollout as a controlled dynamical system

Represent the rollout as a finite-horizon staged process with phases (states) $\{S_0, S_1, \dots, S_8\}$. Let $d_i > 0$ be the planned duration of phase i , and let $\epsilon_i \in [0, 1)$ denote a friction parameter such that the phase completes per unit time with effective rate proportional to $(1 - \epsilon_i)$. A simple expected-time model is

$$\mathbb{E}[T] = \sum_{i=0}^8 \frac{d_i}{1 - \epsilon_i},$$

so for small frictions ($\epsilon_i \approx 0$) the planned 12–18 month window remains stable, while large frictions inflate completion time superlinearly as $\epsilon_i \uparrow 1$.

6.5. Contingency and cultural economics

Resistance to strict verification can be modeled via a logistic adoption curve

$$A(t) = \frac{1}{1 + e^{-k(t-t_0)}},$$

where $A(t) \in (0, 1)$ is workforce compliance, $k > 0$ is the adoption steepness, and t_0 is the inflection time. Psychological safety initiatives increase k (faster adoption) and shift t_0 left (earlier uptake) ([Sutton et al., 2025](#); [Kim et al., 2025](#)).

6.6. Cost summary in Net Present Value (NPV) terms

Let I_t be implementation cost at time index t (e.g., years or quarters), B_t benefit, and $r > 0$ the discount rate. The net present value over horizon T is

$$\text{NPV} = \sum_{t=0}^T \frac{B_t - I_t}{(1+r)^t}.$$

When I_t is front-loaded and B_t increases over time due to cumulative risk suppression and operational efficiency, the marginal contribution to NPV becomes positive beyond an initial stabilization period. (Formally, for discrete time, this is expressed via finite differences ΔNPV_t , rather than a derivative.)

6.7. Summary and justification

Mathematically, a strict passwordless-first and Zero Trust-aligned architecture suppresses adversarial success probability across multiple control dimensions (capture, persistence, device feasibility, and propagation). Economically, expected loss decreases under proportional suppression of success probabilities and, under thinning-and-severity reductions, yields improved expected utility for risk-averse decision makers. Operationally, reducing credential-driven alert volumes can drive nonlinear reductions in SOC queueing delays near capacity, improving responsiveness. Taken together, the stochastic, queueing, and economic models support the conclusion that the proposed control framework is *analytically predicted to yield* a structurally improved risk posture, operational efficiency, and long-term economic advantage. These conclusions are subject to the enforcement coverage assumptions and parameter regimes specified throughout this section, and remain pending empirical validation in operational enterprise environments.

7. Parameter estimation, sensitivity analysis, and simulation framework

The mathematical guarantees in this manuscript are *conditional*: they hold under explicit assumptions on enforcement coverage, policy strictness, and observable rates derived from enterprise telemetry. This section operationalizes the framework by: (i) specifying how key parameters can be estimated from real-world logs and incident records; (ii) characterizing sensitivity regimes when idealized dominance assumptions do not hold; and (iii) providing a reproducible simulation methodology that distinguishes *conditional guarantees* (model-level) from *realistic outcomes* (deployment-level) under partial enforcement and operational constraints. The goal is not to claim universal zero-risk, but to provide a *formally specified and analytically tractable* framework for suppressing credential-harvesting success and post-compromise utility, consistent with large-scale breach evidence ([Verizon, 2025](#); [Proof-point, 2024](#)) and with the empirically observed limits of training-only interventions ([Ho et al., 2025](#); [Lain et al., 2024](#); [Delso-Vicente et al., 2025](#); [Hwang, 2025](#); [Öner, 2025](#)). Verifiability in operational settings remains contingent on empirical calibration using first-hand enterprise telemetry, which is beyond the scope of the present work and constitutes a primary limitation thereof.

7.1. Parameter identification from enterprise telemetry

We map the core model parameters to observables available in modern enterprise environments (cloud IdP logs, conditional-access decision records, endpoint telemetry, SIEM/SOAR alerts, and incident-response case management). Throughout, we emphasize estimators that are auditable and computable from standard security data sources. Where appropriate, we explicitly distinguish *configuration parameters* (known by design) from *stochastic parameters* (to be estimated from data), and we report uncertainty where the data-generating process is only approximately stationary.

Compromise-arrival intensity λ_{comp} . Let $N_{\text{comp}}(T)$ denote the number of *session-compromise* events observed over a horizon of length T (e.g., confirmed session hijacks, token theft events, or credential-based account takeovers resulting in active sessions). Under a stationary Poisson approximation, $N_{\text{comp}}(T) \sim \text{Poisson}(\lambda_{\text{comp}}T)$ and a natural estimator is

$$\hat{\lambda}_{\text{comp}} = \frac{N_{\text{comp}}(T)}{T}.$$

Under the Poisson model, an exact $(1 - \alpha)$ confidence interval for λ_{comp} follows by χ^2 inversion:

$$\lambda_{\text{comp}} \in \left[\frac{1}{2T} \chi_{2N_{\text{comp}}(T), \alpha/2}^2, \frac{1}{2T} \chi_{2(N_{\text{comp}}(T)+1), 1-\alpha/2}^2 \right],$$

with the usual convention that the lower bound is 0 when $N_{\text{comp}}(T) = 0$. In practice, organizations may only partially observe compromises. To mitigate undercount bias, one can define $N_{\text{comp}}(T)$ using a conservative case definition based on incident confirmations and high-confidence detections (e.g., “impossible travel” followed by sensitive actions, token replay detections, IDP risk events leading to forced sign-out), and report uncertainty by stratifying events into “confirmed” vs. “probable” categories. Since credential abuse is repeatedly reported as a dominant intrusion vector in large-scale breach telemetry (Verizon, 2025; Proofpoint, 2024), even conservative baselines provide actionable calibration points.

Re-authentication rate $\rho = 1/\tau$. The enforced re-authentication rate is a policy parameter determined by the maximum re-authentication interval $\tau > 0$ (e.g., conditional-access revalidation, step-up authentication, continuous access evaluation). Thus

$$\rho = \frac{1}{\tau}$$

is known by configuration. Empirically, the effective re-authentication cadence may differ from nominal due to token lifetimes, refresh behavior, session continuity mechanisms, and exemptions. Let $N_{\text{step}}(T)$ be the number of observed step-up (re-authentication) events over horizon T for a population of N_{users} users (or, more generally, N_{sessions} sessions). A transparent per-user intensity estimator is

$$\hat{\rho}_{\text{eff}} = \frac{N_{\text{step}}(T)}{T N_{\text{users}}},$$

with role-, application-, or risk-tier stratification as needed (policies are often tiered). If policies induce heterogeneous re-authentication across users, report $\hat{\rho}_{\text{eff}}$ as a distribution (e.g., per-role medians and quantiles) rather than a single aggregate.

Automated revocation rate μ_{rev} and expiry rate δ_{exp} (competing risks). In the post-compromise lifetime model (Section 7.3), the conditional exploitation lifetime L is modeled as exponential with hazard

$$\kappa = \rho + \mu_{\text{rev}} + \delta_{\text{exp}}, \quad \Pr(L > t) = e^{-\kappa t}, \quad \mathbb{E}[L] = \frac{1}{\kappa}.$$

To estimate $(\mu_{\text{rev}}, \delta_{\text{exp}})$, it is essential to separate (a) revocations triggered by detection (forced sign-out, token invalidation, session termination, account disable), from (b) expiries/rotations enforced irrespective of detection (hard TTL, key rotation, privileged token expiry).

Let $\{(L_j, Z_j)\}_{j=1}^m$ be observed post-compromise lifetimes for m compromised sessions, where L_j is the time from compromise to invalidation, and $Z_j \in \{\text{reauth}, \text{rev}, \text{exp}\}$ labels the dominant termination mechanism (forced re-authentication, detection-driven revocation, or expiry/rotation), when such labeling is available from logs.

(i) **Estimating the aggregate hazard κ .** Under i.i.d. $L_j \sim \text{Exp}(\kappa)$, the maximum-likelihood estimator is

$$\hat{\kappa} = \frac{m}{\sum_{j=1}^m L_j},$$

and $\sum_{j=1}^m L_j \sim \text{Gamma}(m, \kappa)$ yields standard confidence intervals for κ via Gamma or χ^2 inversion.

(ii) **Estimating cause-specific hazards (preferred when labels exist).** Under independent exponential competing risks with cause-specific hazards $(\rho, \mu_{\text{rev}}, \delta_{\text{exp}})$, the probability that termination occurs by cause c is κ_c/κ , and the cause-specific MLEs are

$$\hat{\rho} = \frac{m_{\text{reauth}}}{\sum_{j=1}^m L_j}, \quad \hat{\mu}_{\text{rev}} = \frac{m_{\text{rev}}}{\sum_{j=1}^m L_j}, \quad \hat{\delta}_{\text{exp}} = \frac{m_{\text{exp}}}{\sum_{j=1}^m L_j},$$

where $m_c := \#\{j : Z_j = c\}$ and $m_{\text{reauth}} + m_{\text{rev}} + m_{\text{exp}} = m$. In many deployments, ρ is policy-known by configuration; the above provides an empirical cross-check for realized enforcement.

(iii) **Conservative estimation when cause labels are unavailable.** If only $\{L_j\}$ are observed (no Z_j), then one can estimate $\hat{\kappa}$ as above and

recover a conservative revocation rate by subtracting policy-known components:

$$\hat{\mu}_{\text{rev}} = \max\{0, \hat{\kappa} - \rho - \delta_{\text{exp}}\},$$

where δ_{exp} is computed from configured TTL/rotation schedules. This yields an auditable lower bound on detection-driven revocation intensity consistent with the model assumptions.

Device attestation coverage and feasible endpoint ratio. Let $D(T)$ be the set of distinct devices attempting access over horizon T , and let $\mathcal{A}(T) \subseteq D(T)$ be the subset that satisfy attestation and policy compliance at the time of access. The empirical attestation coverage is

$$\hat{S}_{\text{eff}} = \frac{|\mathcal{A}(T)|}{|D(T)|},$$

computed from MDM/EDR posture and IdP device-claim logs. Since strict enforcement denies access for $D(T) \setminus \mathcal{A}(T)$, this quantity is operationally measurable and directly adjustable via rollout gating (e.g., tightening admission policy and shrinking exception paths).

Zero trust movement matrix M and gating matrix P . In the lateral-movement model (Section 7.3), M encodes baseline pivot feasibility and P encodes per-edge authorization acceptance. Both can be estimated from access graphs and decision logs.

Let $G = (V, E)$ be constructed from identity-to-resource access logs, where V comprises principals and services/resources, and edges represent observed or policy-permitted access transitions. Over a time window T :

- Estimate baseline transition weights M_{ij} from historical feasibility and privilege structure. One auditable approach is to set M_{ij} proportional to the frequency of attempted pivots from i to j in high-risk contexts, and then normalize by an exposure term (e.g., number of opportunities), or alternatively to encode policy-allowed reachability under least-privilege design.
- Estimate P_{ij} from conditional-access decisions:

$$\hat{P}_{ij} = \frac{\#\{\text{allowed requests on } (i, j) \text{ during } T\}}{\#\{\text{attempted requests on } (i, j) \text{ during } T\}},$$

stratified by device posture, location, and risk signals when policies are context-dependent.

Then

$$M' = P \circ M$$

is computable and the containment objective is to enforce $\rho(M') < 1$.

7.2. Sensitivity regimes and non-ideal enforcement

The analytical guarantees of this framework are sensitive to the degree of enforcement coverage and to the validity of the modeling assumptions. This subsection characterizes the principal sensitivity regimes and identifies conditions under which the formal results may not transfer directly to operational deployments. The central quantity governing post-compromise sensitivity is the total invalidation hazard

$$\kappa = \rho + \mu_{\text{rev}} + \delta_{\text{exp}},$$

which decouples compromise frequency (λ_{comp}) from post-compromise decay (κ) and enables direct sensitivity analysis with respect to each defender-controlled component.

Post-compromise utility sensitivity. For any fixed compromise frequency λ_{comp} , the expected compromised time over horizon T satisfies (Section 7.1)

$$\mathbb{E}[\mathcal{T}_{\text{comp}}(T)] = \lambda_{\text{comp}} T \cdot \frac{1}{\kappa}.$$

Therefore, for any component $\kappa_c \in \{\rho, \mu_{\text{rev}}, \delta_{\text{exp}}\}$,

$$\frac{\partial}{\partial \kappa_c} \mathbb{E}[\mathcal{T}_{\text{comp}}(T)] = -\lambda_{\text{comp}} T \cdot \frac{1}{\kappa^2} < 0.$$

Partial passwordless enforcement. Let $c_{\text{pwdless}} \in [0, 1]$ denote the fraction of authentication events (or accounts) covered by passwordless-only enforcement with no fallback to reusable secrets. A conservative upper bound for capture probability is the convex combination

$$P_{\text{capture}} \leq (1 - c_{\text{pwdless}}) P_{\text{capture}}^{\text{pwd}} + c_{\text{pwdless}} P_{\text{capture}}^{\text{phy}},$$

where $P_{\text{capture}}^{\text{pwd}}$ corresponds to password-based exposure (phishing/stuffing/reuse) and $P_{\text{capture}}^{\text{phy}}$ to residual physical/device compromise.

Partial device attestation and exceptions. Let $c_{\text{att}} \in [0, 1]$ denote the fraction of access attempts covered by strict attestation enforcement (no exception path). Then a conservative bound on device-feasibility is

$$P_{\text{device}} \leq (1 - c_{\text{att}}) + c_{\text{att}} \cdot \hat{S}_{\text{eff}}.$$

Zero trust strictness and spectral margin. The key lateral-containment metric is the spectral radius $\rho(M') = \rho(P \circ M)$. Define the *spectral margin*

$$\Delta := 1 - \rho(M').$$

Containment corresponds to $\Delta > 0$; conversely, $\Delta \leq 0$ indicates super-critical propagation risk in the multi-type branching approximation, implying that lateral movement is not self-limiting under the current enforcement regime.

7.3. Simulation methodology (reproducible and parameterized)

To bridge conditional mathematical results to realistic outcomes, we propose a simulation framework parameterized by estimable quantities from Section 7.1. The simulator produces distributions over attacker success and operational impact under varying enforcement coverage and operational constraints, thereby separating *conditional guarantees* (model-level) from *indicative outcomes under synthetic parameterizations* (deployment-level exploration). It is emphasized that simulation results generated from hypothetical parameter ranges do not constitute empirical validation and should not be interpreted as deployment guarantees. Real-world outcomes will depend on the degree to which the simulator's parameters reflect actual enterprise telemetry, a correspondence that has not been empirically established in the present work.

(i) *Session compromise and invalidation (Monte Carlo).* Over horizon T , simulate compromise arrivals

$$N_{\text{comp}}(T) \sim \text{Poisson}(\lambda_{\text{comp}} T),$$

then draw i.i.d. conditional exploitation lifetimes

$$L_i \sim \text{Exp}(\kappa), \quad \kappa = \rho + \mu_{\text{rev}} + \delta_{\text{exp}}.$$

Compute the total compromised time

$$\mathcal{T}_{\text{comp}}(T) = \sum_{i=1}^{N_{\text{comp}}(T)} L_i.$$

(ii) *Lateral propagation on an enterprise graph (multi-type branching simulation).* Given M and P , compute $M' = P \circ M$ and its spectral radius $\rho(M')$. For simulation, initialize Z_0 as an initial compromise vector and evolve a discrete-time multi-type branching approximation. One explicit scheme is: for each time step t and each currently compromised node i with $Z_t(i) > 0$, sample attempted child compromises to each j according to independent Poisson offspring

$$Y_{ij}^{(t)} \sim \text{Poisson}(Z_t(i) M'_{ij}),$$

and set

$$Z_{t+1}(j) = \sum_{i \in V} Y_{ij}^{(t)}.$$

Table 1

Monte Carlo micro-example (independent Poisson thinning) for annual loss under baseline (X_0) versus post-control (X_1). Settings: $n = 20,000$, $\gamma = 10^{-6}$. Lower CE_{loss} is preferred. The certainty-equivalent gain is defined as $\Delta CE := CE_{\text{loss}}(X_0) - CE_{\text{loss}}(X_1)$, so $\Delta CE > 0$ indicates improvement under CARA risk aversion.

Metric	Baseline X_0	Post-control X_1
Mean	107,981.24	26,887.00
Median	81,798.01	5,691.81
90th percentile	232,297.43	77,733.48
95th percentile	298,284.48	115,500.99
99th percentile	471,579.67	227,681.18
Maximum	1,422,103.73	1,681,157.34
CE_{loss}	113,653.74	28,377.78
Certainty-equivalent gain: $\Delta CE = 85,275.96 (>0)$.		

(iii) *End-to-end success probability and economic loss (link to Section 6.2).* For a target asset set $V_{\text{tgt}} \subseteq V$, define a success event S . The simulation estimates

$$\hat{P}_{\text{succ}} = \Pr(S)$$

under specified enforcement and threat-model parameters. Combine with the loss model (Section 6.2) to estimate expected residual risk.

7.4. Micro-example simulation I: annual-loss Monte Carlo (static thinning) and tail check

To concretely demonstrate how the above framework is instantiated, we report a Monte Carlo micro-example for the annual loss variable used in the economic model. The objective of this micro-example is not empirical validation, but an auditable illustration of how model parameters map to output distributions and how post-control suppression affects both central tendency and tail risk under the stated assumptions. All parameter values are hypothetical; results should not be interpreted as predictions of outcomes in specific enterprise deployments.

We simulated $n = 20,000$ annual-loss scenarios under a baseline regime (X_0) and a post-control regime (X_1) reflecting reduced successful-event intensities (via thinning/suppression). For CARA risk aversion we used $\gamma = 10^{-6}$ (Section 6.2). Table 1 summarizes the empirical distributions and the derived loss certainty equivalents $CE_{\text{loss}}(X) = \gamma^{-1} \ln(\mathbb{E}[e^{\gamma X}])$.

As an empirical dominance sanity check, at representative thresholds t (chosen as baseline quantiles) the simulation yields:

$$\Pr(X_1 > 0) = 0.5310 \leq 0.9509 = \Pr(X_0 > 0),$$

$$\Pr(X_1 > 81,798.01) = 0.0929 \leq 0.5000 = \Pr(X_0 > 81,798.01),$$

$$\Pr(X_1 > 232,297.43) = 0.0094 \leq 0.1000 = \Pr(X_0 > 232,297.43),$$

$$\Pr(X_1 > 298,284.48) = 0.0046 \leq 0.0500 = \Pr(X_0 > 298,284.48),$$

$$\Pr(X_1 > 471,579.67) = 0.0013 \leq 0.0100 = \Pr(X_0 > 471,579.67).$$

7.5. Micro-example simulation II: adaptive adversary (batch Thompson sampling) and tail check

A key concern in realistic deployments is *adversary adaptation*: as certain channels become less effective (e.g., password phishing under passwordless-only enforcement), attackers shift effort toward residual pathways (e.g., device compromise, insider-like abuse, consent-based attacks). To illustrate this effect in a transparent way, we ran a second Monte Carlo micro-example in which the attacker is modeled as a learning agent selecting among multiple attack modes using *batch Thompson sampling* (Beta-Binomial updating). In each epoch, the adversary allocates attempts to the mode that maximizes a sampled expected payoff,

Table 2

Monte Carlo micro-example with an *adaptive* adversary (batch Thompson sampling) under baseline (X_0) versus post-control (X_1). Settings: $n = 20,000$, epochs = 12, attempts/epoch = 200, batch = 10, $\gamma = 10^{-6}$. Lower CE_{loss} is preferred.

Metric	Baseline X_0	Post-control X_1
Mean	2,039,252.71	487,579.81
Median	1,867,792.79	203,925.67
90th percentile	3,210,921.74	1,280,366.58
95th percentile	3,758,614.09	1,871,744.13
99th percentile	5,494,812.76	3,891,429.04
Maximum	20,726,664.97	23,456,221.02
CE_{loss}	10,843,697.00	13,716,739.21
Certainty-equivalent difference: $\Delta CE := CE_{\text{loss}}(X_0) - CE_{\text{loss}}(X_1) = -2,873,042.21$. ($\Delta CE < 0$ indicates deterioration under risk aversion).		

then updates posteriors from observed successes. Defender controls enter as (i) multiplicative suppression factors θ per mode and (ii) reduced session persistence through κ .

We simulated $n = 20,000$ annual-loss trajectories with 12 epochs, 200 attempts/epoch, and batch size 10; CARA aversion uses $\gamma = 10^{-6}$. It is acknowledged that these hyperparameters are hypothetical and have not been calibrated against empirical attack telemetry. The results of this micro-example should therefore be interpreted as a qualitative illustration of adaptive reallocation dynamics rather than as a quantitative prediction of adversary behavior in real deployments. Calibration of adversary model parameters against observed attack campaign data, including attempt frequencies, mode selection distributions, and per-mode success rates, constitutes an important avenue for future empirical work. Table 2 reports the resulting annual-loss distributions.

Despite substantial reductions in central tendency and in right-tail probabilities at representative thresholds (below), the certainty equivalent under CARA can increase if the post-control distribution exhibits sufficiently heavier extreme outcomes in rare scenarios. This occurs here because CE_{loss} is governed by the exponential functional $\ln \mathbb{E}[e^{\gamma X}]$ and is therefore highly sensitive to extreme realizations. In operational terms, this emphasizes that strong median/tail improvements at conventional quantiles should be complemented by explicit stress testing and scenario controls on residual “catastrophic” pathways (e.g., high-impact device compromise or insider-like abuse), which are precisely the pathways an adaptive adversary reallocates effort toward. **Why the certainty equivalent can worsen.** For $\gamma > 0$, the loss certainty equivalent is the entropic risk measure

$$CE_{\text{loss}}(X) = \frac{1}{\gamma} \log \mathbb{E}[e^{\gamma X}].$$

The mapping $X \mapsto \log \mathbb{E}[e^{\gamma X}]$ is *convex* (by Hölder’s inequality), hence CE_{loss} is convex as well: for any $\alpha \in [0, 1]$ and losses X, Y ,

$$CE_{\text{loss}}(\alpha X + (1 - \alpha)Y) \leq \alpha CE_{\text{loss}}(X) + (1 - \alpha) CE_{\text{loss}}(Y).$$

Therefore, rare but very large realizations receive exponentially increasing weight and can dominate CE_{loss} even when standard quantiles improve.

As a distributional sanity check, at representative thresholds t (chosen as baseline quantiles), the simulation yields:

$$\Pr(X_1 > 0) = 0.7554 \leq 1.0000 = \Pr(X_0 > 0),$$

$$\Pr(X_1 > 1,867,792.79) = 0.0501 \leq 0.5000 = \Pr(X_0 > 1,867,792.79),$$

$$\Pr(X_1 > 3,210,921.74) = 0.0158 \leq 0.1000 = \Pr(X_0 > 3,210,921.74),$$

$$\Pr(X_1 > 3,758,614.09) = 0.0109 \leq 0.0500 = \Pr(X_0 > 3,758,614.09),$$

$$\Pr(X_1 > 5,494,812.76) = 0.0037 \leq 0.0100 = \Pr(X_0 > 5,494,812.76).$$

Table 3

Adaptive adversary effort reallocation under batch Thompson sampling: empirical proportion of total attack attempts allocated to each mode (baseline vs. post-control). Shares are computed over all simulated attempts and sum to approximately 100% within each regime.

Attack mode	Baseline share	Post-control share
Password phishing	29.25%	12.27%
OAuth consent abuse	20.84%	15.31%
Device theft/physical compromise	20.85%	30.43%
Insider abuse	29.07%	41.99%

7.6. Adaptive adversary behavior: effort reallocation

To make adaptation explicit and auditable, Table 3 reports the empirical share of attempts allocated to each attack mode under baseline vs. post-control. Consistent with the model, post-control enforcement suppresses reusable-credential channels and shifts adversary effort toward residual pathways (notably device compromise and insider-like abuse).

7.7. Conditional vs. realistic guarantees

The core analytical results of this manuscript are *conditional* statements of monotone suppression and threshold behavior:

- Passwordless-only coverage increases the difficulty of scalable credential capture, reducing P_{capture} relative to password-based baselines (Verizon, 2025; Proofpoint, 2024).
- Continuous verification and automated revocation reduce post-compromise utility through $\Pr(L > t) = e^{-\kappa t}$ and $\mathbb{E}[L] = 1/\kappa$ (Sections 4–5), without any conflated rate assumptions.
- Per-request Zero Trust containment is governed by $\rho(M') < 1$ rather than hop-independence (Section 4), capturing privilege correlation and heterogeneous enterprise topology.

Real-world enterprise environments may exhibit partial enforcement (coverage < 1), heterogeneous policy exceptions, and adaptive adversary behavior. The estimation and simulation framework above is therefore essential: it quantifies how far a given organization is from the theoretical enforcement regime (via coverage and measured rates) and provides sensitivity curves showing how incremental policy tightening reduces measurable risk while highlighting residual “hard” channels that dominate rare extreme outcomes.

Summary. This section provides an auditable mapping from model parameters to enterprise telemetry and a reproducible simulation methodology for validating sensitivity and partial-enforcement scenarios. It directly addresses empirical-grounding concerns by enabling organizations to estimate $(\lambda_{\text{comp}}, \rho, \mu_{\text{rev}}, \delta_{\text{exp}}, M, P)$ from their own data, compute threshold metrics such as $\rho(M')$, and produce simulation-based distributions of attacker success and operational impact consistent with large-scale breach observations (Verizon, 2025; Proofpoint, 2024) and the documented limits of awareness-only controls (Ho et al., 2025; Lain et al., 2024; Delso-Vicente et al., 2025; Hwang, 2025; Öner, 2025).

8. Legal and regulatory alignment (EU and Spain)

The proposed strict posture—passwordless-only authentication, continuous re-authentication, device attestation, per-request Zero Trust validation, and compulsory credential expiry—is designed to *support* and, in well-scoped enterprise environments operating under the stated threat model, potentially *exceed* the risk-reduction intent embedded in European and Spanish cybersecurity and data-protection instruments. Importantly, regulatory compliance is inherently *risk-based* rather than zero-risk based. Accordingly, we avoid absolute-zero claims and instead formalize alignment in terms of *asymptotically negligible* residual risk under progressively stricter enforcement.

Risk-based compliance formalization. Let $\mathcal{R} > 0$ denote a regulatory tolerance threshold expressed as an acceptable residual risk level (context-dependent and determined by proportionality, state-of-the-art, and organizational risk assessment). Let the realized residual risk under a given control portfolio be represented by

$$\mathcal{R}_{\text{real}} = \mathbb{E}[X],$$

where X is the (random) annual loss under the implemented controls, as formalized in Section 6.2. A common compliance-oriented risk-management objective is

$$\mathcal{R}_{\text{real}} \leq \mathcal{R}.$$

To connect explicitly to the manuscript's attack-success decomposition, one may further upper-bound $\mathbb{E}[X]$ by conditioning on a "success" event. Let S denote an adversarial success event (initial compromise followed by consequential impact) and write $P_{\text{succ}} := \Pr(S)$. Define X_S as the loss random variable conditional on S . Then, without assuming any independence,

$$\mathbb{E}[X] = \mathbb{E}[X | S] \Pr(S) + \mathbb{E}[X | S^c] \Pr(S^c) \leq \mathbb{E}[X | S] P_{\text{succ}} + \mathbb{E}[X | S^c].$$

If $\mathbb{E}[X | S^c]$ is treated as the (typically lower) baseline of non-success losses (e.g., blocked attacks, near-misses, minor incidents), then the dominant compliance-relevant term is often the product

$$P_{\text{succ}} \cdot \mathbb{E}[X | S],$$

which justifies using P_{succ} as a primary technical control target while preserving a formally correct expected-loss objective.

In this manuscript, P_{succ} is suppressed along multiple dimensions through (i) elimination of reusable secrets via passwordless-only authentication; (ii) reduction of post-compromise utility via continuous verification and automated revocation (increasing $\kappa = \rho + \mu_{\text{rev}} + \delta_{\text{exp}}$); (iii) reduction of endpoint feasibility via device attestation; and (iv) containment of propagation via per-request Zero Trust gating with effective movement matrix $M' = P \circ M$. Rather than asserting $P_{\text{succ}} = 0$, we adopt an asymptotic statement: within the stated threat model, under strengthening enforcement, P_{succ} can be made arbitrarily small.

Formally, regard P_{succ} as a function of enforcement parameters (coverage and strictness). Let $c_{\text{pwdless}} \in [0, 1]$ be passwordless-only coverage, $c_{\text{att}} \in [0, 1]$ strict attestation coverage, and let $\kappa = \rho + \mu_{\text{rev}} + \delta_{\text{exp}}$ be the post-compromise invalidation rate. Suppose enforcement is strengthened so that

$$c_{\text{pwdless}} \rightarrow 1, \quad c_{\text{att}} \rightarrow 1, \quad \kappa \rightarrow \infty, \quad \rho(M') \rightarrow 0.$$

Then, within the manuscript's threat model (excluding nation-state hardware compromise and comparable out-of-scope capabilities), the limiting behavior is

$$\lim_{c_{\text{pwdless}} \rightarrow 1, c_{\text{att}} \rightarrow 1, \kappa \rightarrow \infty, \rho(M') \rightarrow 0} P_{\text{succ}} = 0.$$

Consequently, for any target $\varepsilon > 0$, there exists a sufficiently strict enforcement regime such that

$$P_{\text{succ}} < \varepsilon,$$

and therefore the dominant contribution $P_{\text{succ}} \cdot \mathbb{E}[X | S]$ can be made arbitrarily small if $\mathbb{E}[X | S]$ is finite (as assumed in Section 6.2 via finite mean severities). This captures the intended meaning of *asymptotically negligible* residual risk: residual risk is nonzero in principle, but can be reduced below any prescribed tolerance within scope.

GDPR and ePrivacy/LSSI. Article 32 of the GDPR requires "state-of-the-art" technical and organizational measures appropriate to risk. Let the deployed control portfolio be summarized by a vector

$$\mathbf{C} = (C_{\text{auth}}, C_{\text{device}}, C_{\text{monitor}}, C_{\text{access}}),$$

capturing authentication strength (passwordless and phishing-resistant FIDO2/WebAuthn), device integrity enforcement (attestation), monitoring and automated response (revocation), and per-request authorization (Zero Trust). Let $\Phi(\mathbf{C})$ denote the induced reduction in P_{succ} (or,

more generally, in the loss functional $\mathbb{E}[X]$) relative to a baseline. Then Article 32 alignment requires that $\mathbf{C}$ be proportionate and state-of-the-art, i.e., it yields a materially improved $\Phi(\mathbf{C})$ under relevant threat models. The proposed measures satisfy this by (a) suppressing scalable credential replay and password reuse exposure via phishing-resistant authentication and origin binding, and (b) reducing post-compromise utility through continuous verification and revocation (Verizon, 2025; Proofpoint, 2024).

Breach notification timeliness (Arts. 33–34) is operationally supported by reduced detection latency through continuous telemetry and automated session invalidation. In the model, stronger monitoring increases μ_{rev} and decreases the expected exploitation lifetime

$$\mathbb{E}[L] = \frac{1}{\rho + \mu_{\text{rev}} + \delta_{\text{exp}}},$$

thereby reducing the time available for undetected misuse and improving the feasibility of timely identification and reporting.

NIS2. NIS2 requires appropriate technical and organizational measures for managing cybersecurity risks, including incident handling, business continuity, and secure access controls. In the present framework, per-request Zero Trust validation suppresses propagation by ensuring the effective movement matrix $M' = P \circ M$ satisfies a subcriticality condition $\rho(M') < 1$ (Section 7.2), yielding almost-sure extinction of lateral movement in the idealized branching approximation and under the stated enforcement assumptions, with strong containment expected in practice under sufficiently strict policy enforcement. This supports NIS2-aligned risk management by converting transitive trust into continuously evaluated, context-bound authorization (Verizon, 2025).

DORA. DORA emphasizes ICT risk management and operational resilience, including prevention, detection, response, and recovery. The strict posture reduces account-takeover probability and materially shortens post-compromise exploitation windows by increasing $\kappa = \rho + \mu_{\text{rev}} + \delta_{\text{exp}}$, with survival probability $\Pr(L > t) = e^{-\kappa t}$. While not asserting zero probability of compromise, the model supports resilience objectives by bounding and shrinking attacker dwell time and limiting propagation, thereby reducing the likelihood that an initial compromise escalates into systemic disruption (Verizon, 2025; Federal Bureau of Investigation, Internet Crime Complaint Center (IC3), 2024).

PSD2 RTS-SCA and eIDAS 2. Strong customer authentication (SCA) and high-assurance authentication requirements are supported by hardware-bound, origin-specific credentials (FIDO2/WebAuthn). In the manuscript's threat model, these controls drive the probability of successful credential replay and scalable password-phishing capture toward an arbitrarily small level under sufficiently comprehensive enforcement. Formally, there exists a nonincreasing function $\varepsilon_{\text{cap}}(\cdot)$ of enforcement strictness such that

$$P_{\text{capture}} \leq \varepsilon_{\text{cap}},$$

where $\varepsilon_{\text{cap}} \rightarrow 0$ as passwordless-only coverage and origin binding become comprehensive. This aligns with the intent of phishing-resistant authentication and reduces exposure of credential-based fraud channels (Verizon, 2025; Proofpoint, 2024).

This aligns with the intent of phishing-resistant authentication and reduces exposure of credential-based fraud channels (Verizon, 2025; Proofpoint, 2024).

CRA and ENS (Spain). The CRA emphasizes security-by-design and vulnerability risk reduction across product lifecycles, while the Spanish ENS mandates structured, continuous security management and monitoring. The proposed controls implement security-by-design at the identity and access layer through two complementary mechanisms: (i) *substantially suppressing* the transition classes associated with reusable secrets—and, under full passwordless-only enforcement, eliminating the associated credential-capture surface within the stated threat model; and (ii) enforcing device compliance as an admission control.

Device attestation reduces feasible endpoint access by restricting operations to $\mathcal{A} \subseteq \mathcal{D}$ (Section 7.1), and continuous monitoring increases revocation rate μ_{rev} , jointly reducing P_{succ} and shrinking exploitation lifetimes.

Summary. The proposed architecture is aligned with EU and Spanish frameworks by operationalizing “state-of-the-art” access controls, continuous monitoring, and risk-based management. The key formal statement is not that risk becomes exactly zero, but that under increasingly strict enforcement (passwordless coverage, attestation coverage, per-request authorization strictness, and rapid invalidation), the residual success probability and associated expected-loss contribution can be made asymptotically negligible within the stated threat model, thereby supporting the risk-reduction intent embedded in GDPR, NIS2, DORA, PSD2 (RTS-SCA), eIDAS 2, the CRA, and the ENS (Verizon, 2025; Proofpoint, 2024; Federal Bureau of Investigation, Internet Crime Complaint Center (IC3), 2024). This alignment is structural and analytical in nature; formal regulatory compliance determination requires case-by-case legal assessment and, where applicable, empirical demonstration of control effectiveness in deployment, neither of which is provided in the present manuscript.

9. Limitations and threat model assumptions

Let the adversary model be formalized as a capability set

$$\mathcal{A} = \{\mathcal{A}_{\text{phish}}, \mathcal{A}_{\text{session}}, \mathcal{A}_{\text{lateral}}\},$$

excluding nation-state hardware-level compromise. Our mathematical results hold under the assumption that the enterprise IdP can enforce device attestation and that the reject set

$$\mathcal{D} \setminus \mathcal{A}_{\text{attested}}$$

is applied deterministically. Legacy ecosystems with fragmented identity infrastructure reduce applicability.

Empirical scope. All quantitative results in this manuscript are derived from mathematical models and parameterized simulations. No real-world pilot, deployment study, or first-hand enterprise telemetry dataset has been used to calibrate the model parameters λ_{comp} , ρ , μ_{rev} , δ_{exp} , M , and P . Consequently, the practical correspondence between the modeled parameter ranges and conditions encountered in specific operational environments remains unestablished. The mathematical guarantees presented—including monotone suppression of P_{succ} , exponential decay of post-compromise utility $\Pr(L > t) = e^{-\kappa t}$, and subcritical containment via $\rho(M') < 1$ —are *conditional* on the stated threat model and enforcement assumptions, and should not be interpreted as unconditional deployment guarantees.

Simulation parameterization. The Monte Carlo micro-examples reported in Sections 7.4 and 7.5 employ hypothetical parameter values that have not been empirically validated against observed enterprise attack campaigns. In particular, the adversary hyperparameters (epoch count, attempt volume, batch size, and mode-specific suppression factors) are illustrative constructs. Results should be interpreted as qualitative sensitivity illustrations rather than quantitative predictions of real deployment outcomes.

10. Employee privacy and ethics

Continuous authentication uses telemetry features $X_i \in \mathbb{R}^d$. GDPR-compliant processing requires:

$$\min_M \|X_i - M(X_i)\|^2 \quad \text{s.t.} \quad \dim(M(X_i)) \leq d_{\min},$$

representing data minimization. A DPIA ensures convex feasibility of the privacy–security trade-off:

$$\min_{p \in [0,1]} \alpha \mathcal{R}(p) + \beta \mathcal{P}(p),$$

where $\mathcal{P}(p)$ is privacy intrusion and $\mathcal{R}(p)$ residual risk.

11. Conclusions and future directions

This work develops a unified socio-technical and mathematical framework for reducing credential-harvesting risk in enterprise communication systems. Rather than relying on high-variance human vigilance, the proposed architecture formalizes risk suppression through infrastructure-enforced mechanisms: passwordless-only authentication, device attestation, continuous re-authentication, automated revocation, and per-request Zero Trust validation.

Multi-dimensional risk suppression. Let the global success probability of an adversarial campaign be decomposed as

$$P_{\text{succ}} = P_{\text{capture}} \cdot P_{\text{valid|capture}} \cdot P_{\text{lateral}} \cdot P_{\text{impact}},$$

where:

- P_{capture} reflects credential or session acquisition;
- $P_{\text{valid|capture}}$ reflects post-compromise persistence;
- P_{lateral} reflects propagation across the enterprise graph;
- P_{impact} reflects successful reach of high-value targets.

The framework reduces each component through independently enforceable control dimensions:

1. **Capture suppression:** Passwordless, phishing-resistant authentication reduces scalable credential replay and stuffing exposure, driving

$$P'_{\text{capture}} = \theta_{\text{cap}} P_{\text{capture}}, \quad 0 < \theta_{\text{cap}} < 1.$$

2. **Post-compromise decay:** Continuous verification yields exponential exploitation decay

$$\Pr(L > t) = e^{-\kappa t}, \quad \kappa = \rho + \mu_{\text{rev}} + \delta_{\text{exp}},$$

with

$$\mathbb{E}[L] = \frac{1}{\kappa}.$$

Increasing κ monotonically reduces attacker utility without requiring dominance assumptions.

3. **Propagation containment:** Per-request Zero Trust induces an effective movement matrix

$$M' = P \circ M,$$

and containment corresponds to the subcriticality condition

$$\rho(M') < 1,$$

ensuring that lateral propagation becomes a subcritical branching process in the multi-type approximation.

4. **Endpoint restriction:** Device attestation reduces the feasible access set $\mathcal{A} \subseteq \mathcal{D}$ and lowers transition feasibility in M' .

These dimensions act multiplicatively but need not be statistically independent. The framework does not assume hop-independence nor absolute-zero probabilities; instead, it provides monotone suppression and threshold-based containment guarantees under explicit parameter regimes.

Asymptotic behavior and engineering dominance. Under strengthening enforcement (increasing passwordless coverage, increasing κ , reducing critical P_{ij} entries in P , and minimizing policy exceptions), one obtains

$$\lim_{\kappa \rightarrow \infty, \rho(M') \rightarrow 0} P_{\text{succ}} = 0$$

within the stated threat model. *Within the formal model*, this implies that residual success probability decreases monotonically as enforcement parameters tighten, and can in principle be made arbitrarily small relative to baseline architectures that rely on reusable secrets and transitive trust. This result is conditional on the threat model

assumptions detailed in Section 8 and the adversary capability set $\mathcal{A}$ defined in the Limitations section, and does not constitute a deployment guarantee under partial enforcement or adversary capabilities outside the modeled set.

Importantly, this is an *asymptotic engineering result*, not a claim of absolute immunity. Residual risks remain under advanced endpoint compromise, insider threats, and adversary capabilities outside the assumed model. However, within realistic enterprise constraints, the framework shifts credential harvesting from a structurally favored attack vector to a constrained, policy-limited process with quantifiable bounds.

Economic implications. Let X_0 and X_1 denote annual loss random variables before and after enforcement. Under proportional suppression

$$p'_i = \theta_i p_i, \quad 0 < \theta_i < 1,$$

one obtains

$$\mathbb{E}[X_1] < \mathbb{E}[X_0],$$

and, under Poisson thinning with unchanged or reduced severities,

X_1 is stochastically smaller than X_0 ,

implying strictly higher expected utility for risk-averse decision makers. Thus, the framework is economically justified not through absolute elimination of incidents, but through systematic suppression of both mean loss and tail exposure.

Overall contribution. The principal theoretical contribution is the replacement of a human-dependent stochastic defense variable

H (high variance, context-dependent)

with infrastructure-enforced control parameters

$$(\rho, \mu_{\text{rev}}, \delta_{\text{exp}}, P, M)$$

whose effects on residual risk are analytically tractable and monotone.

The principal practical contribution is an operationalizable framework linking:

- enterprise telemetry,
- measurable parameters,
- spectral containment thresholds,
- expected loss models,
- and regulatory risk alignment.

Empirical limitations. A primary limitation of the present work is the absence of empirical validation through real-world deployment or controlled case study. All quantitative results are derived from mathematical models and parameterized simulations whose inputs are either hypothetical or drawn from aggregated industry breach reports (Verizon, 2025; Proofpoint, 2024; Federal Bureau of Investigation, Internet Crime Complaint Center (IC3), 2024), rather than from first-hand enterprise telemetry. As a consequence, the extent to which the modeled parameter ranges reflect conditions in specific operational environments—particularly with respect to compromise arrival rate λ_{comp} , effective re-authentication cadence $\hat{\rho}_{\text{eff}}$, and enforcement coverage c_{pwdless} and c_{att} —remains unestablished. Future work should prioritize empirical calibration of the proposed framework against real enterprise datasets and, where feasible, incorporate a small-scale deployment study to assess the practical validity of the model's sensitivity predictions and threshold metrics such as the spectral margin $\Delta = 1 - \rho(M')$.

Future research directions. Several avenues extend this work:

- Empirical calibration of κ and spectral margins $\Delta = 1 - \rho(M')$ across diverse enterprise datasets.
- Game-theoretic modeling of adaptive adversaries under threshold-based Zero Trust constraints.

- Non-exponential lifetime models (e.g., heavy-tailed or Lévy-type dynamics) for advanced persistent threats.
- Formal integration of NIST and EU regulatory risk frameworks into unified spectral-risk metrics.

In summary, the evidence and formal results presented here support a clear engineering conclusion: passwordless-first, continuously verified, attested, and per-request-authorized architectures provide structurally superior risk suppression compared to legacy credential-based and perimeter-trust models. While no complex system admits absolute zero risk, the proposed framework provides a mathematically tractable basis for suppressing residual credential-harvesting risk toward asymptotically negligible levels *within the scope of the formal model and under its stated assumptions*. Whether these theoretical limits translate to operationally verifiable risk reduction requires empirical calibration against real-world telemetry, including first-hand enterprise data on compromise rates, enforcement coverage, and re-authentication cadence, which remains an important direction for future work and constitutes a primary limitation of the present manuscript.

CRediT authorship contribution statement

Guillermo Cotrina Cuenca: Writing – review & editing, Writing – original draft, Validation, Methodology, Investigation, Formal analysis, Conceptualization. **Alberto Peinado Domínguez:** Writing – review & editing, Writing – original draft, Visualization, Validation, Methodology, Investigation, Formal analysis.

Declaration of competing interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper. The publication costs of this article will be covered by the authors' affiliated university.

Data availability

Data will be made available on request.

References

- Delso-Vicente, C., Díaz-Marcos, V., de Blanes-Sebastián, M.G., 2025. Factors influencing employee compliance with information security policies: A systematic literature review. *Futur. Bus. J.* 11 (1), 32. <http://dx.doi.org/10.1186/s43093-025-00452-7>, URL: <https://fbj.springeropen.com/articles/10.1186/s43093-025-00452-7>.
- Federal Bureau of Investigation, 2025. FBI releases annual internet crime report. Press release summarizing 2024 IC3 losses and volumes <https://www.fbi.gov/news/press-releases/fbi-releases-annual-internet-crime-report>.
- Federal Bureau of Investigation, Internet Crime Complaint Center (IC3), 2024. Internet Crime Report 2024. Tech. rep., FBI IC3, URL: https://www.ic3.gov/AnnualReport/Reports/2024_IC3Report.pdf.
- Ho, G., Mirian, A., Luo, E., Tong, K., Lee, E., Liu, L., Longhurst, C.A., Dameff, C., Savage, S., Voelker, G.M., 2025. Understanding the efficacy of phishing training in practice. In: 2025 IEEE Symposium on Security and Privacy. SP, IEEE, URL: https://people.cs.uchicago.edu/~grantho/papers/oakland2025_phishing-training.pdf.
- Hoxhunt, 2025. Phishing trends report (updated for 2025). Reports 64% of organizations facing BEC in 2024; (Accessed 19 September 2025) URL: <https://hoxhunt.com/guide/phishing-trends-report>.
- Hwang, J., 2025. Boosting employee information security compliance: The roles of IS policy awareness, threat perception, task-technology fit, and person-organization fit. *Humanit. Soc. Sci. Commun.* 12 (1), 1–12. <http://dx.doi.org/10.1057/s41599-025-04718-x>, URL: <https://www.nature.com/articles/s41599-025-04718-x>.
- Infosecurity Magazine, 2024. Report reveals 341% rise in advanced phishing attacks. <https://www.infosecurity-magazine.com/news/341-rise-advanced-phishing-attacks/>.
- Jabir, R., Naeem, M., et al., 2025. Phishing attacks in the age of generative artificial intelligence (genai): A systematic review and future directions. *Digital* 6 (8), 174. <http://dx.doi.org/10.3390/digital6080174>, URL: <https://www.mdpi.com/2673-2688/6/8/174>.

- Kim, B.-J., Yoon, H.-R., et al., 2025. How corporate social responsibility promotes employees' cybersecurity behavior: The mediating role of psychological safety and the moderating role of perfectionism climate. *Humanit. Soc. Sci. Commun.* 12 (1), 1–15. <http://dx.doi.org/10.1057/s41599-025-04511-w>, URL: <https://www.nature.com/articles/s41599-025-04511-w>.
- Lain, D., Jost, T., Matetic, S., Kostiaainen, K., Capkun, S., 2024. Content, nudges and incentives: A study on the effectiveness and perception of embedded phishing training. In: *Proceedings of the 2024 ACM SIGSAC Conference on Computer and Communications Security*. CCS, <http://dx.doi.org/10.1145/3658644.3690348>.
- Öner, U., 2025. Human factors in phishing: Understanding susceptibility and reporting behavior in organizational contexts. *Saf. Sci.* 180, 106490. <http://dx.doi.org/10.1016/j.ssci.2025.106490>, URL: <https://www.sciencedirect.com/science/article/abs/pii/S0920548925000431>.
- Proofpoint, 2024. 2024 State of the Phish Report. Tech. rep., Proofpoint, URL: <https://www.proofpoint.com/us/resources/threat-reports/state-of-phish>.
- SlashNext, 2024. SlashNext mid-year state of phishing report shows 341% increase in BEC and advanced phishing attacks. <https://www.prnewswire.com/news-releases/slashnext-mid-year-state-of-phishing-report-shows-341-increase-in-bec-and-advanced-phishing-attacks-302152148.html>.
- SlashNext Threat Labs, 2024. The State of Phishing 2024: Midyear Report. Tech. rep., SlashNext, URL: <https://slashnext.com/wp-content/uploads/2024/05/SlashNext-The-State-of-Phishing-24-Midyear-Report.pdf>.
- Sutton, S., Jayne, C., et al., 2025. Towards a cybersecurity culture-behaviour framework. *Comput. Secur.* 139, 103811. <http://dx.doi.org/10.1016/j.cose.2024.103811>, URL: <https://www.sciencedirect.com/science/article/pii/S0167404824004152>.
- Verizon, 2025. 2025 Data Breach Investigations Report. Tech. rep., Verizon, URL: <https://www.verizon.com/business/resources/reports/dbir/> Includes statistic on stolen credentials in Basic Web Application Attacks.